

Лекция. 10 Угрозы безопасности информации на сетевом уровне модели OSI

Учебные вопросы:

1. Угрозы безопасности сетевого уровня модели OSI.
2. Атаки на протоколы маршрутизации.

1. Угрозы безопасности сетевого уровня модели OSI

На сетевом уровне модели OSI мы видим так называемый Интернет-протокол (IP), там же и ICMP, который является частью Интернет-протокола. Уровень 3 уязвим для многочисленных DoS-атак и атак с раскрытием конфиденциальности.

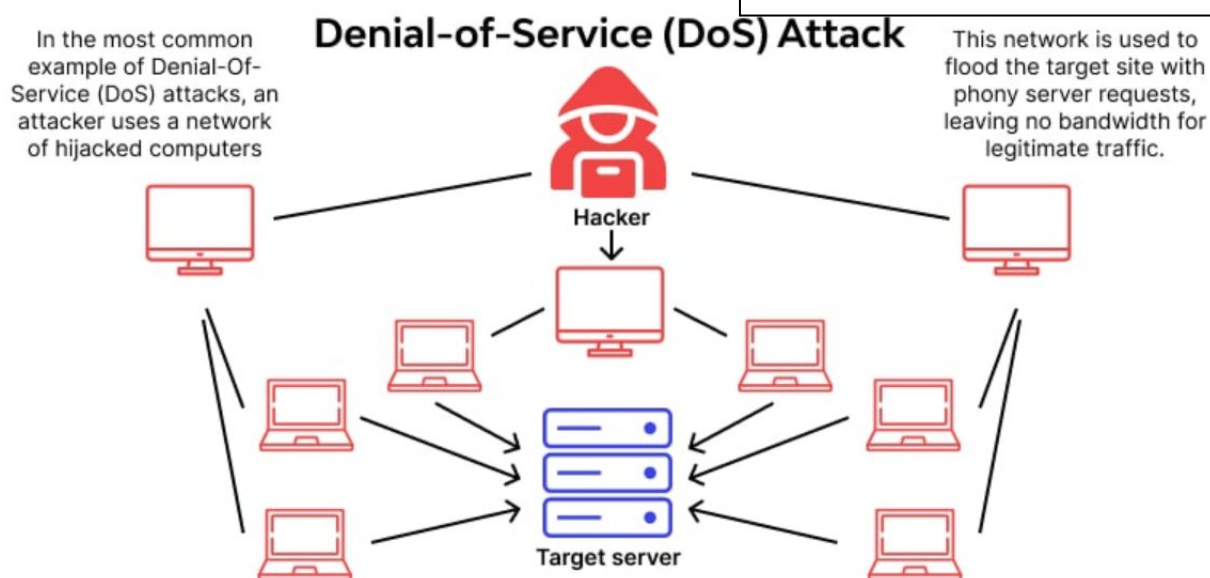


Рис. 1 Реализация DDOS-атаки

Перехват пакетов (Packet Sniffing)

Ранее мы обсуждали проблему перехвата и то, как злоумышленники в коммутируемой сети могут перехватывать сообщения, которые им не принадлежат. Если сеть не коммутируется (например, используется концентратор), анализ пакетов становится намного проще.

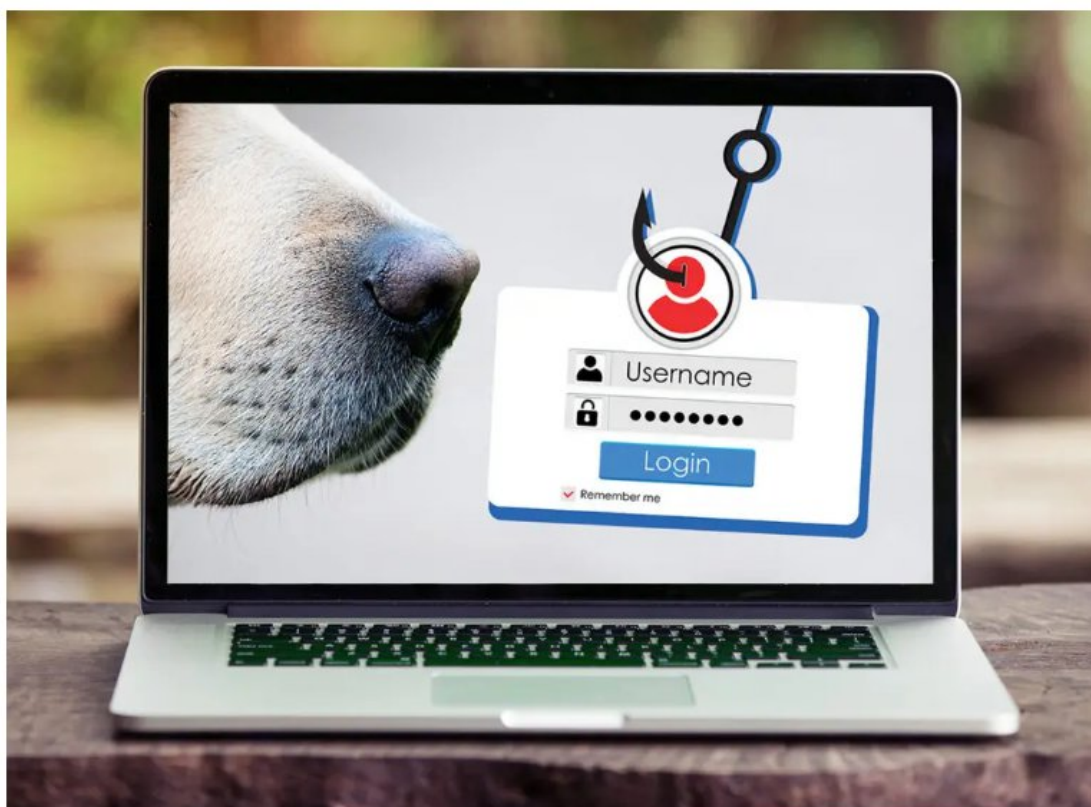
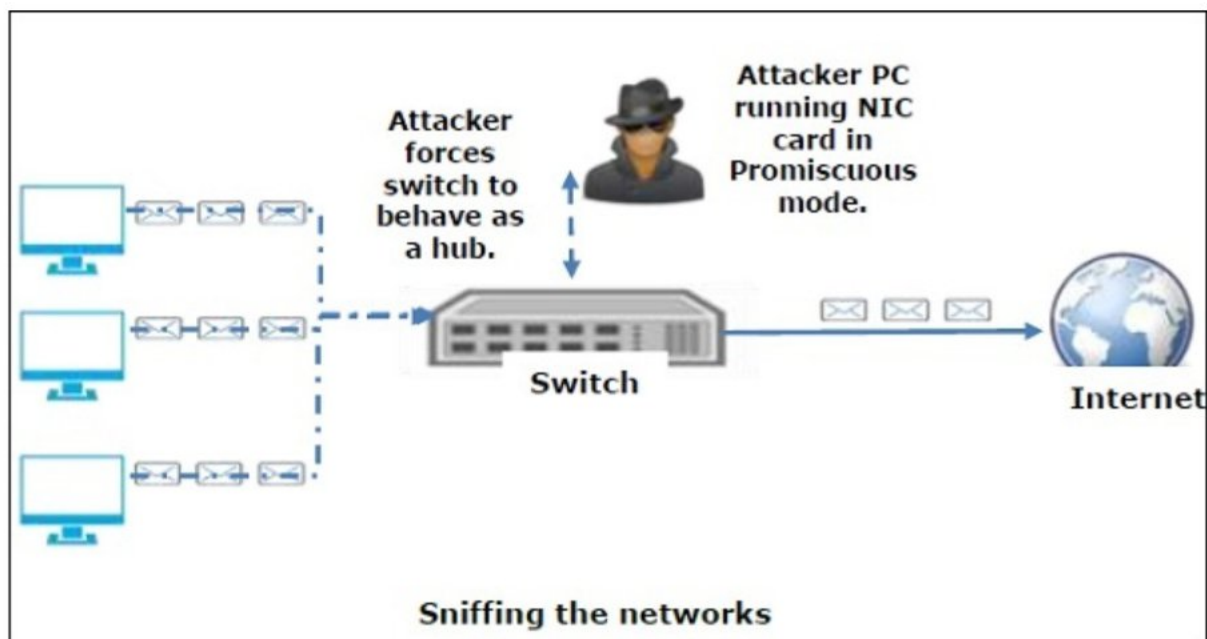


Рис. 2 Перехват пакетов (Packet Sniffing)

Перехват пакетов означает захват IP-трафика с помощью таких инструментов, как `dsniff`, `tcpdump`, `ethereal` и т. д. Поскольку поток данных с верхних уровней инкапсулируется в IP-пакеты, вся информация с этих уровней может быть раскрыта при анализе (декапсуляции) IP-пакетов.

Такие протоколы, как POP3, SMTP, SNMP и т. д., передают пароли в открытом виде, поэтому декодирование захваченных IP-пакетов может привести к раскрытию таких конфиденциальных данных. Снифферы пакетов, такие как dsniff, имеют очень хорошие инструменты для декодирования этих пакетов и сохранения этой информации в файле в виде открытого текста.

Защита уровня 2 (канального) с помощью управляемых коммутаторов может значительно снизить эффективность анализаторов/перехватчиков пакетов в сети. Кроме того, создание зашифрованных VPN с использованием IPSec или других средств шифрования снизит вероятность перехвата данных почти до нуля.

IP-спуфинг (IP Spoofing)

Злоумышленник может подделать доверенный IP-адрес при общении с хостом, чтобы получить несанкционированный доступ к этому хосту. В Интернете можно найти множество инструментов для подмены IP-адресов.

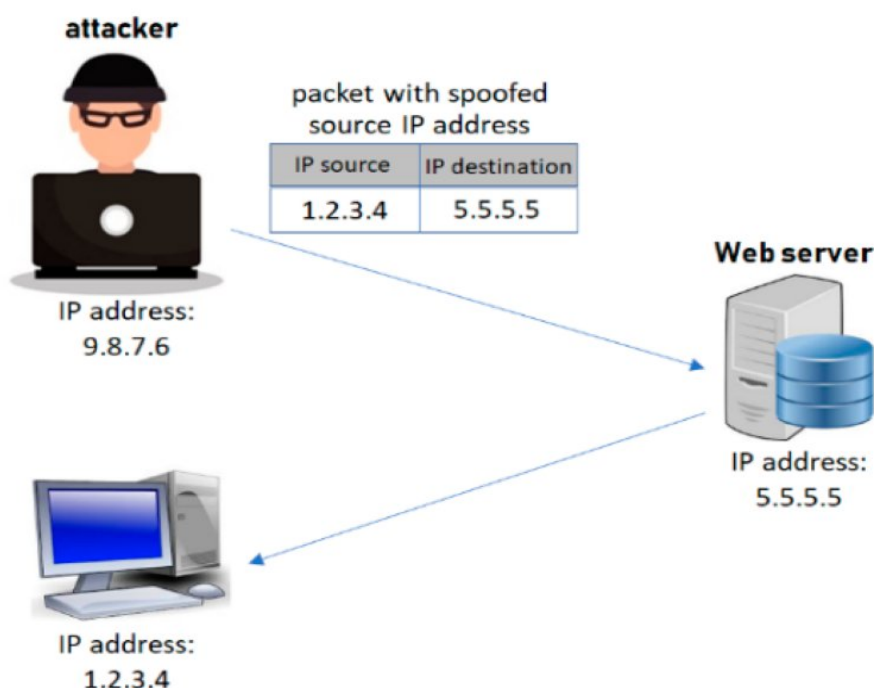


Рис. 3 IP – спуфинг (IP Spoofing)

Используя подмену/спуфинг IP, злоумышленники также могут инициировать отказ в обслуживании, отправляя данные с поддельным исходным IP-адресом на атакуемый IP-адрес. Получатель будет отправлять ответы, которые могут содержать большие объемы данных, что приведёт к излишней загрузке, а возможно и к перегрузке.

Отправка данных с использованием поддельного IP-адреса не с одного хоста, а с целой группы хостов, приведет к распределенной атаке типа «отказ в обслуживании».

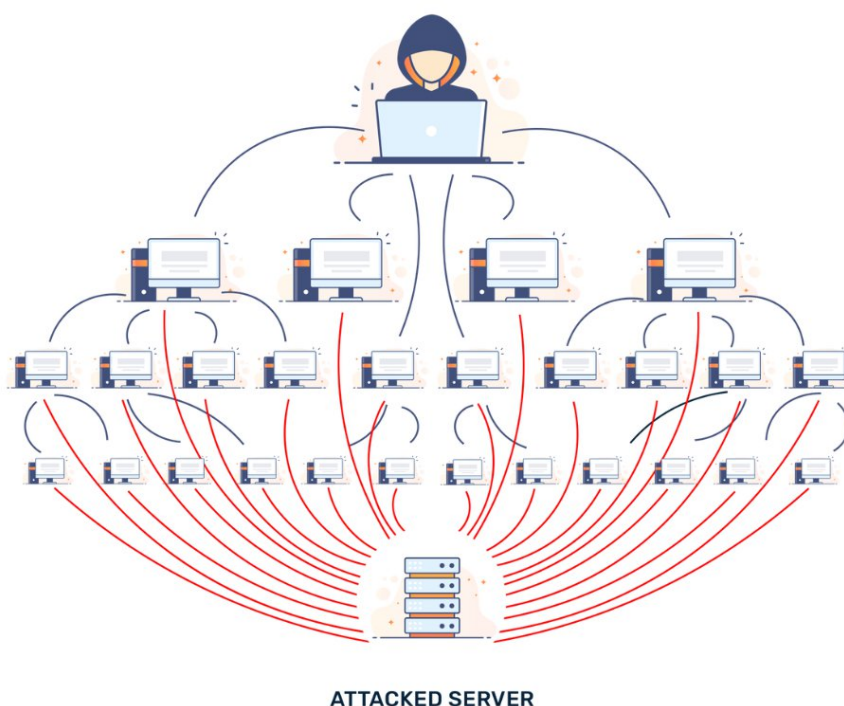


Рис. 4 Отправка данных с использованием поддельных IP-адресов

Для защиты от подмены IP-адресов в ядре Linux есть параметр с именем «rp_filter», который можно изменить во время выполнения, используя:

```
root@router:~# echo 0 > /proc/sys/net/ipv4/conf/all/rp_filter
```

Эта команда отключает rp_filter на всех интерфейсах. Чтобы отключить на одном интерфейсе, например, eth0, мы можем использовать:

```
root@router:~# echo 0 > /proc/sys/net/ipv4/conf/eth0/rp_filter
```

Установка `rp_filter` на:

- ~ 1 включает защиту от спуфинга IP
- ~ 0 отключает защиту от спуфинга IP

IP-пакеты, приходящие с одного хоста, входят в машину на Linux на одном интерфейсе. Ответы на эти IP-пакеты должны исходить из того же интерфейса, если для `rp_filter` установлено значение 1.

rp = reverse path (обратный путь)

Фильтрация обратного пути - это механизм, принятый ядром Linux, а также большинством сетевых устройств для проверки маршрутизации исходного адреса принимающего пакета.

Другими словами, когда машина с включенной фильтрацией обратного пути получает пакет, она сначала проверяет, **доступен** ли источник полученного пакета через интерфейс, в который он пришел.

Если он маршрутизируется через интерфейс, на который пришел, то машина примет пакет. Если он не маршрутизируется через интерфейс, на который пришел, то машина этот пакет отбросит.

2. Атаки на протоколы маршрутизации

Неправильно настроенные протоколы динамической маршрутизации, такие как RIP, BGP и OSPF, могут позволить



злоумышленникам внедрить маршруты в таблицы маршрутизации машин, на которых запущены экземпляры этих протоколов. Это может позволить злоумышленникам проводить атаки типа «отказ в обслуживании», внедряя неправильные маршруты или прослушивая IP-адреса, настроив свой

компьютер для работы в качестве маршрутизатора из сети.

ICMP-атаки

ICMP - важная часть IP-протокола, позволяющая узлам и маршрутизаторам обмениваться управляющими сообщениями.

Используя поддельные IP-адреса, злоумышленник может нарушить связь между двумя хостами, отправив сообщения «Time Exceeded» или «Destination Unreachable» на оба хоста, что приведет к DoS-атаке.

Отправляя ICMP-сообщения о перенаправлении, злоумышленник может заставить маршрутизатор пересылать пакеты, предназначенные одному хосту, на IP-адрес злоумышленника.

В Linux мы можем заставить ядро не принимать сообщения перенаправления для одного или всех интерфейсов:

```
root@router:~# echo 0 > /proc/sys/net/ipv4/conf/eth0/accept_redirects
```

ICMP Flooding - один из самых простых способов атаки на хост.

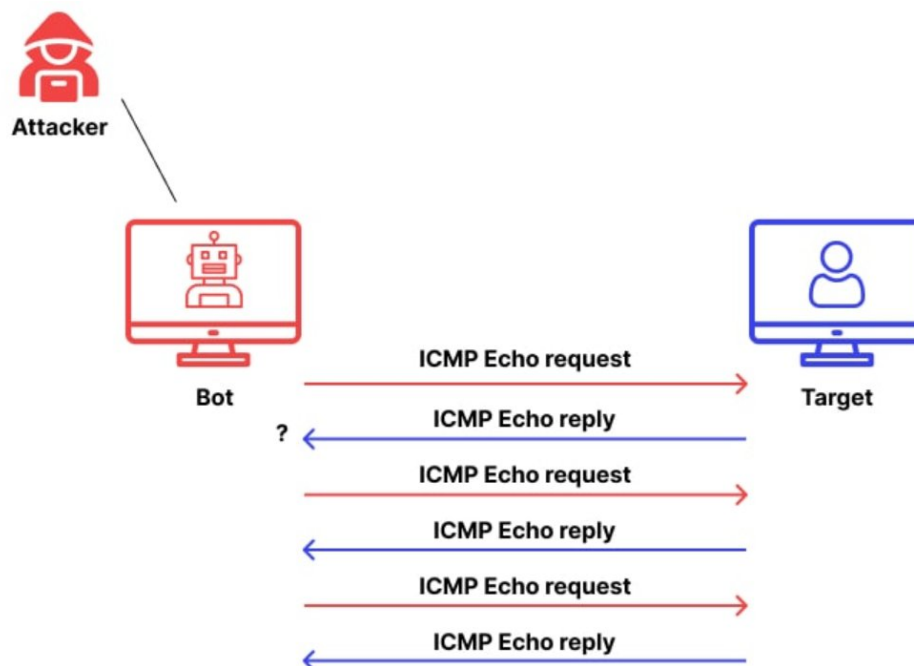


Рис. 5 ICMP Flooding

Ping - один из наиболее часто используемых инструментов для проверки подключения, но его также можно использовать в качестве инструмента DoS-атаки.

Например, в Linux можно «зафлудить»/«затопить» хост командой `ping -f`. Следующая команда заполняет хост 10.10.10.17 тысячью пакетами:

```
root@router:~# ping -f 10.10.10.12 -c 1000
```

```
PING 10.10.10.12 (10.10.10.12) 56(84) bytes of data.
```

Этот тип атаки можно остановить, ограничив количество сообщений эхо-запроса ICMP с помощью инструмента iptables:

```
root@router:~# iptables -A FORWARD -p icmp --icmp-type echo-request -m
```

```
limit --limit 10/s -j ACCEPT
```

```
root@router:~# iptables -A FORWARD -p icmp --icmp-type echo-request -j DROP
```

iptables - очень мощный инструмент по фильтрации трафика, которому следует посвятить отдельную статью, если не целую серию практических статей.

А пока ниже приводится схема блоков, через которые можно просеивать трафик:

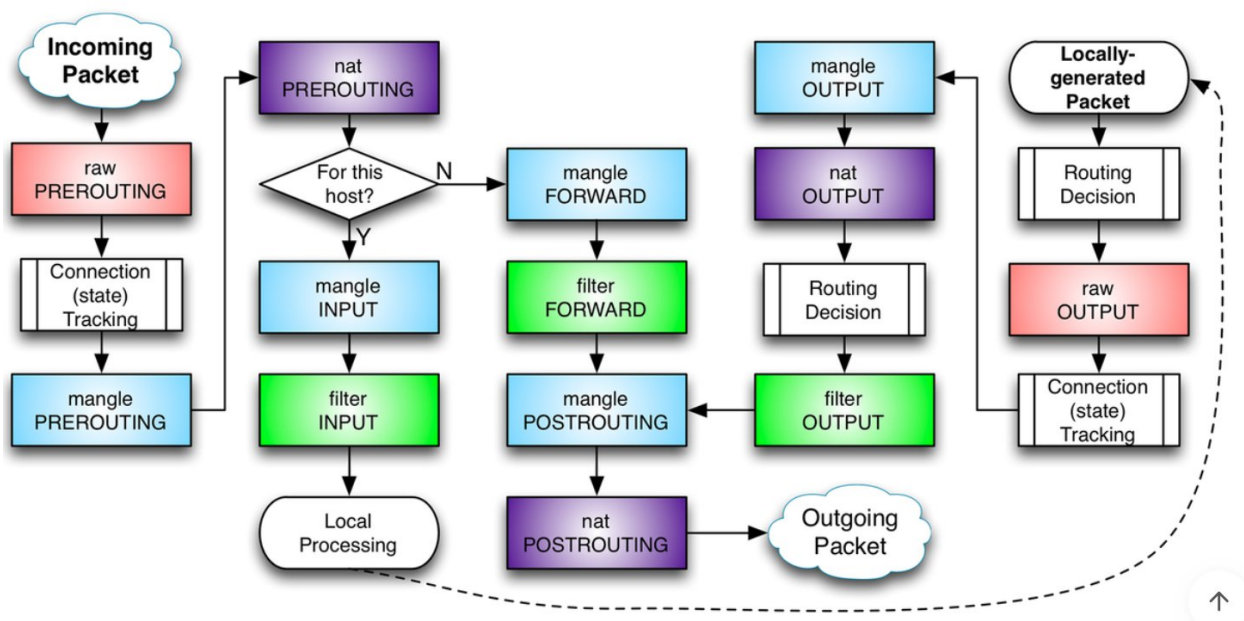


Рис. 6 Блок - схема

В старых реализациях ICMP были и другие уязвимости; например, Смертельный Пинг (Ping of Death). Реализация ping of death приводила

к сбою машин, отправляя сообщения ICMP «эхо-запрос» в IP-пакетах, длина которых превышала максимально допустимую длину в 65535 октетов/байтов, что вызывало переполнение буфера и приводило к сбою устройства жертвы (компьютера, принтера и т. д.).

Ping of Death attack

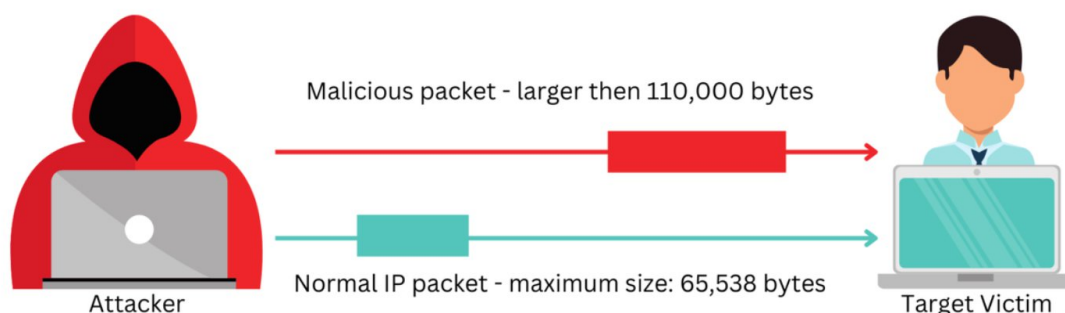


Рис. 7 «Смертельный ping»

Патч Linux для ping of death был выпущен через 2 часа 35 минут и 10 секунд, а вскоре после этого у поставщиков стали доступны патчи для других ОС.

Тем не менее, проблема ping of death породила тенденцию к фильтрации ICMP-пакетов, что не является хорошей практикой.

«Слёзная» атака

Teardrop, targa, NewTear, Nestea Bonk, Boink, TearDrop2, Syndrop и многие другие — всё это инструменты для аварийного завершения работы машин, имеющих уязвимость в IP.

Эти инструменты используют ошибку фрагментации в реализации IP некоторых старых ядер Linux (2.0), Windows NT и Windows 95. Результатом атаки была паника ядра в Linux (kernel panic — это когда ядро Linux попадает в состояние невозстановимого сбоя) или синий экран в Windows. Перезагрузка решила проблему до следующей атаки.